

Tes réponses permettent maintenant de fixer un modèle cohérent. Elles clarifient surtout la distinction entre :

- l'identité globale ;
- l'environnement client ;
- la présence locale d'une société ou d'un opérateur ;
- les droits propres à chaque projet.

Un point doit toutefois être formulé très strictement : **l'isolation des données ne doit jamais reposer uniquement sur les droits des utilisateurs**. Le filtrage par environnement intervient d'abord ; les permissions déterminent ensuite ce que l'utilisateur peut voir dans cet environnement.

Voici la synthèse documentaire que je retiendrais.

Modifier

Architecture d'isolation des données

1. Principe fondamental

Easy Projet est une plateforme multi-clients.

Chaque client dispose d'un environnement de travail propre, constituant la frontière principale d'isolation et de sécurité des données.

Aucune donnée métier appartenant à un environnement client ne peut être consultée, modifiée ou rattachée depuis un autre environnement.

La frontière de sécurité est l' `EnvironnementClient` .

2. Définition du client

Un client Easy Projet est une société ayant acquis au moins une licence.

Société contractante

+

Au moins une licence créée par AXCIO-DATA

=

Environnement client

L'environnement client est créé lors de l'association de la première licence à la société contractante.

Une société contractante ne possède qu'un seul environnement client.

L'environnement continue d'exister après l'échéance de toutes ses licences. L'échéance d'une licence ne provoque donc ni la suppression de l'environnement, ni la suppression de ses données.

3. Société contractante

La société contractante représente l'entité juridique ayant souscrit à Easy Projet.

Elle est créée et administrée par AXCIO-DATA.

Lors de la souscription :

1. AXCIO-DATA recherche si la société existe déjà dans le référentiel global ;
2. la société est créée si elle n'existe pas ;
3. une licence est créée ;
4. la licence est associée à la société ;
5. l'environnement client est créé s'il n'existe pas encore.

Les licences ultérieures sont rattachées au même environnement client.

4. Identité globale des sociétés

La plateforme contient un référentiel global des identités de sociétés.

Cette identité globale contient uniquement des données neutres, publiques ou juridiquement objectives, comparables aux informations disponibles dans des bases publiques.

Exemples :

- raison sociale ;
- nom légal ;
- identifiants légaux ;
- adresse officielle ;
- pays ;
- statut juridique éventuel.

Cette entité peut être nommée `Company`.

Une même société réelle ne doit pas être recréée en tant qu'identité globale pour chaque environnement.

`Company`

└─ identité juridique globale et neutre

Le référentiel global ne contient aucune information commerciale, opérationnelle ou confidentielle propre à un client.

5. Présence d'une société dans un environnement

Une société globale peut être présente dans plusieurs environnements clients.

Exemples :

- sous-traitant travaillant pour plusieurs clients ;
- bureau de contrôle ;
- maître d'œuvre ;
- fournisseur ;
- partenaire.

Sa présence dans un environnement constitue une donnée distincte de son identité globale.

Cette relation peut être nommée `EnvironmentCompany`.

`Company`

└─ `EnvironmentCompany` dans environnement A

└─ `EnvironmentCompany` dans environnement B

└─ `EnvironmentCompany` dans environnement C

Chaque `EnvironmentCompany` appartient à un seul environnement.

Elle peut contenir les informations locales propres à la relation entre le client et cette société :

- nom d'usage ;
- type de relation ;
- coordonnées particulières ;
- contacts ;
- commentaires ;
- qualifications ;
- statut actif ;
- date de début de collaboration ;
- date de fin de collaboration ;
- informations administratives internes ;
- données utiles aux projets du client.

Ces informations ne sont jamais partagées automatiquement entre environnements.

La désactivation d'une société dans un environnement n'a aucune incidence sur sa présence dans les autres environnements.

6. Identité globale des opérateurs

Le même principe s'applique aux personnes.

L'opérateur possède une identité globale liée à son compte d'authentification.

Cette partie commune contient notamment :

- identité ;
- adresse électronique de connexion ;
- compte Django ;
- mot de passe sécurisé ;
- statut global de la connexion ;
- informations nécessaires à l'authentification ;
- invitation et activation du compte.

Un opérateur peut appartenir à plusieurs environnements clients avec un seul compte de connexion.

Operator

- |— présence dans environnement A
 - |— présence dans environnement B
 - └— présence dans environnement C
-

7. Présence d'un opérateur dans un environnement

La présence d'un opérateur dans un environnement est indépendante de son compte global.

Elle peut contenir :

- environnement ;
- société de rattachement dans cet environnement ;
- profil au niveau de l'environnement ;
- statut actif dans l'environnement ;
- dates de début et de fin ;
- informations administratives locales.

L'administrateur client peut désactiver l'opérateur dans son propre environnement.

Cette désactivation :

- retire ses accès à cet environnement ;
- ne désactive pas son compte global ;
- ne modifie pas ses accès aux autres environnements ;
- conserve son historique.

Seul l'administrateur système AXCIO-DATA peut désactiver globalement le compte de connexion.

8. Niveau environnement

Les rôles ayant une portée sur l'ensemble de l'environnement sont principalement :

- administrateur système ;
- administrateur client.

Selon les règles fonctionnelles retenues, le chef de projet peut également disposer de certaines données communes à l'environnement nécessaires à ses projets.

L'administrateur client peut notamment :

- administrer les sociétés présentes dans son environnement ;
 - administrer les opérateurs de son environnement ;
 - consulter les projets de l'environnement ;
 - créer les données communes nécessaires ;
 - gérer les rattachements et les autorisations locales.
-

9. Niveau projet

Les droits opérationnels des autres utilisateurs sont définis au niveau des projets.

Le projet porte notamment :

- les sociétés intervenantes ;
- les opérateurs affectés ;
- le rôle de chaque opérateur ;
- les lots de travaux ;
- les tâches ;
- les réunions ;
- les documents ;
- les lots et éléments financiers ;
- les risques ;
- les reportings ;
- les données d'exploitation.

Un opérateur peut avoir un rôle différent sur chaque projet.

Exemple :

Opérateur Jean DUPONT

└─ Projet A : chef de projet

└─ Projet B : utilisateur

└─ Projet C : sous-traitant

Les droits du projet ne sont pas déduits uniquement de la présence dans l'environnement. Une affectation explicite au projet est

nécessaire, sauf pour les profils disposant d'une vision globale sur l'environnement.

10. Flux de connexion

Après authentification, le système recherche les projets auxquels l'utilisateur est autorisé à participer.

L'utilisateur accède à une liste consolidée de ses projets.

Connexion

↓

Identification de l'opérateur global

↓

Recherche des appartenances actives aux environnements

↓

Recherche des affectations actives aux projets

↓

Présentation de la liste des projets accessibles

Chaque projet affiché doit préciser au minimum :

- son nom ;
- la société cliente ou l'environnement concerné ;
- le rôle de l'utilisateur ;
- son statut.

Lorsqu'un projet est sélectionné, le système détermine automatiquement :

- l'environnement courant ;
- le projet courant ;
- le rôle courant ;
- les permissions applicables.

L'utilisateur ne doit pas avoir à sélectionner manuellement un environnement avant de choisir son projet.

11. Propriété des données

Les données métier appartiennent à l'environnement client.

À l'intérieur de cet environnement, leur visibilité dépend ensuite du rôle et des affectations de l'utilisateur.

Deux niveaux sont distingués.

Niveau environnement

Vision sur les données communes et, selon le profil, sur tout ou partie des projets.

Profils principaux :

- administrateur client ;
- chef de projet, dans la limite de ses responsabilités.

Niveau projet

Vision uniquement sur les projets auxquels l'utilisateur participe.

Profils principaux :

- utilisateur ;
- compagnon ;
- sous-traitant ;
- autres intervenants opérationnels.

12. Données globales à la plateforme

Les données globales sont limitées aux informations réellement communes :

- identités neutres des sociétés ;
- identités et comptes d'authentification des opérateurs ;
- catalogues globaux ;
- paramètres système ;
- licences ;
- informations d'administration AXCIO-DATA ;
- versions de l'application et de la base.

Une donnée globale ne doit pas contenir d'informations confidentielles propres à un client.

13. Données propres à un environnement

Sont propres à un environnement client :

- les présences locales des sociétés ;
 - les présences locales des opérateurs ;
 - les projets ;
 - les relations avec les intervenants ;
 - les informations administratives locales ;
 - les lots de travaux ;
 - les tâches ;
 - les réunions ;
 - les documents ;
 - la GED ;
 - les risques ;
 - les lots financiers ;
 - les éléments financiers ;
 - les reportings ;
 - les paramètres propres au client ;
 - toutes les données opérationnelles.
-

14. Données propres à un projet

Sont notamment propres au projet :

- les rôles des opérateurs ;
- les affectations ;
- les sociétés intervenantes ;
- les tâches ;
- les lots ;
- les plannings ;
- les documents du projet ;
- les réunions ;
- les risques ;
- les données financières ;
- les relevés d'heures ;
- les données d'exploitation.

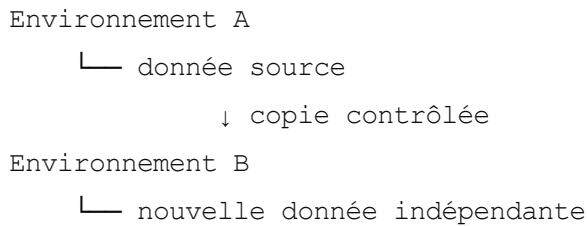
Une donnée projet appartient indirectement à l'environnement du projet.

15. Interdiction de changer d'environnement

Une donnée métier ne peut pas changer d'environnement.

Il est interdit de modifier son environnement d'appartenance après sa création.

Lorsqu'un besoin de transfert est démontré, l'opération doit être réalisée par une fonction explicite de copie.



La copie :

- crée un nouvel identifiant ;
- conserve la donnée d'origine ;
- ne crée pas de lien de dépendance automatique ;
- journalise l'utilisateur, la date, la source et la destination ;
- applique les règles de confidentialité ;
- exclut les données non transférables.

16. Frontière de sécurité

L'environnement client est la première frontière de sécurité.

Toute recherche d'une donnée métier doit obligatoirement inclure l'environnement courant.

Exemple autorisé :

```
Company.objects.get(  
    pk=company_id,  
    environment=current_environment,  
)
```

Exemple interdit :

```
Company.objects.get(pk=company_id)
```

La sécurité s'applique dans cet ordre :

1. Filtrage par environnement
2. Vérification de l'appartenance de l'utilisateur
3. Vérification de son rôle
4. Vérification de son affectation au projet
5. Vérification de l'action demandée

Les droits d'accès ne remplacent jamais le filtrage par environnement.

Un utilisateur ne doit jamais recevoir une donnée d'un autre environnement, même s'il dispose d'un rôle élevé dans son environnement courant.

17. Règles invariantes

Les règles suivantes s'appliquent à tout le projet :

1. Une société contractante possède au maximum un environnement client.
2. L'environnement est créé lors de l'attribution de la première licence.
3. L'environnement persiste après l'échéance des licences.
4. Une identité globale de société peut être présente dans plusieurs environnements.
5. Une identité globale d'opérateur peut être présente dans plusieurs environnements.
6. Les données locales de ces présences ne sont jamais partagées automatiquement.
7. Une donnée métier appartient à un seul environnement.
8. Une donnée ne peut pas être déplacée vers un autre environnement.
9. Un projet appartient à un seul environnement.
10. Toute donnée projet appartient à l'environnement de son projet.
11. Les requêtes métier sont toujours filtrées par environnement.
12. Les permissions sont appliquées après l'isolation par environnement.
13. Une désactivation locale ne produit aucun effet sur les autres environnements.

14. Une désactivation globale relève exclusivement d'AXCIO-DATA.
15. Toute copie entre environnements est explicite, contrôlée et journalisée.

Deux précisions de vocabulaire

Je proposerais de retenir définitivement :

`ClientEnvironment`

pour l'environnement lui-même, et :

`EnvironmentCompany`

pour la présence d'une société dans cet environnement.

Le terme `CompanyEnvironment` pourrait être compris comme la relation société–environnement plutôt que comme la frontière de sécurité.

Le schéma central devient donc :

```
Company contractante
|
├─ License 1
├─ License 2
└─ ClientEnvironment
    ├── EnvironmentCompany
    ├── EnvironmentOperator
    └─ Project
```

Il reste un point à arbitrer avant de figer le modèle : **une licence autorise-t-elle toujours exactement un projet, conformément au principe commercial “un projet = une licence”, ou certaines licences pourront-elles couvrir plusieurs projets ?** Cette cardinalité ne modifie pas l'isolation, mais elle détermine la relation entre `License`, `ClientEnvironment` et `Project`.